

SmartKrishi Implemented Security Features

Short faculty presentation and demonstration guide

Major Security Features

Feature	How it works	Faculty demonstration
Centralized RBAC and ownership control	Central policies restrict Admin, Farmer, Customer, Supplier, Labour, and Agrologist routes. Record-changing queries also verify resource ownership.	Open an Admin route using a Farmer or Customer account. Then attempt to edit another user's order or supply; access is rejected and logged.
TOTP MFA and brute-force protection	Administrator MFA is mandatory. TOTP secrets use AES-256-GCM encryption, recovery codes are hashed, and failed password/MFA attempts are rate limited.	Log in as Admin and show the authenticator-code step. Enter invalid credentials repeatedly to demonstrate temporary blocking.
Secure upload and ClamAV	Uploads are quarantined and checked by size, extension, MIME type, and image structure. ClamAV scans them before storage and filenames are randomized.	Upload a fake image, PHP file, or oversized file to show rejection. Upload a valid image and show its randomized stored filename.
Activity monitoring	Rules detect repeated authorization denials, large or frequent price changes, rapid order updates, and excessive AI feature usage.	Show Admin > Security Activity and run: <code>php security/activity_test.php</code>

Additional Implemented Controls

SQL injection protection: PDO native prepared statements keep user input separate from SQL. Demo: try ' OR '1'='1 on login; authentication must not be bypassed.

CSRF protection: Every POST, PUT, PATCH, and DELETE request requires a random 256-bit session token. Demo: remove or change `_csrf_token` and submit; the server returns HTTP 403.

XSS protection and headers: Output encoding and CSP, nosniff, frame, referrer, and permissions headers reduce script injection and browser attacks. Demo: `submit alert(1);` it must not execute.

Password security: Passwords use Argon2id when available, otherwise bcrypt, and are checked with `password_verify()`. Existing hashes can be upgraded after login.

Security logging: Failed login, CSRF, authorization, upload, malware, and MFA events are written as structured JSON without passwords or raw login identifiers.

OWASP ZAP testing: A scan of 84 discovered URLs found no confirmed SQL injection or XSS alert. Show `storage/reports/zap-report.html`.

Short Faculty Explanation

SmartKrishi goes beyond basic login security. It combines centralized role and ownership authorization, mandatory administrator MFA, brute-force protection, behavior-based activity monitoring, prepared database queries, CSRF and XSS protection, and a ClamAV-backed upload pipeline. Important security events are stored as structured logs, and the application has been tested with OWASP ZAP.

Current Status Note

Wazuh agent and log collection are configured, but custom SmartKrishi alerts are still being troubleshooted in Wazuh Cloud. ModSecurity and OWASP CRS configuration is prepared, but the WAF is not active because the current XAMPP installation lacks a compatible ModSecurity module.